

DEVSECOPS & PLATFORM · ISSUE 01 OF 08

Shift-left security in CI/CD.

Block new risk. Burn down old risk. Never the other way round.

01

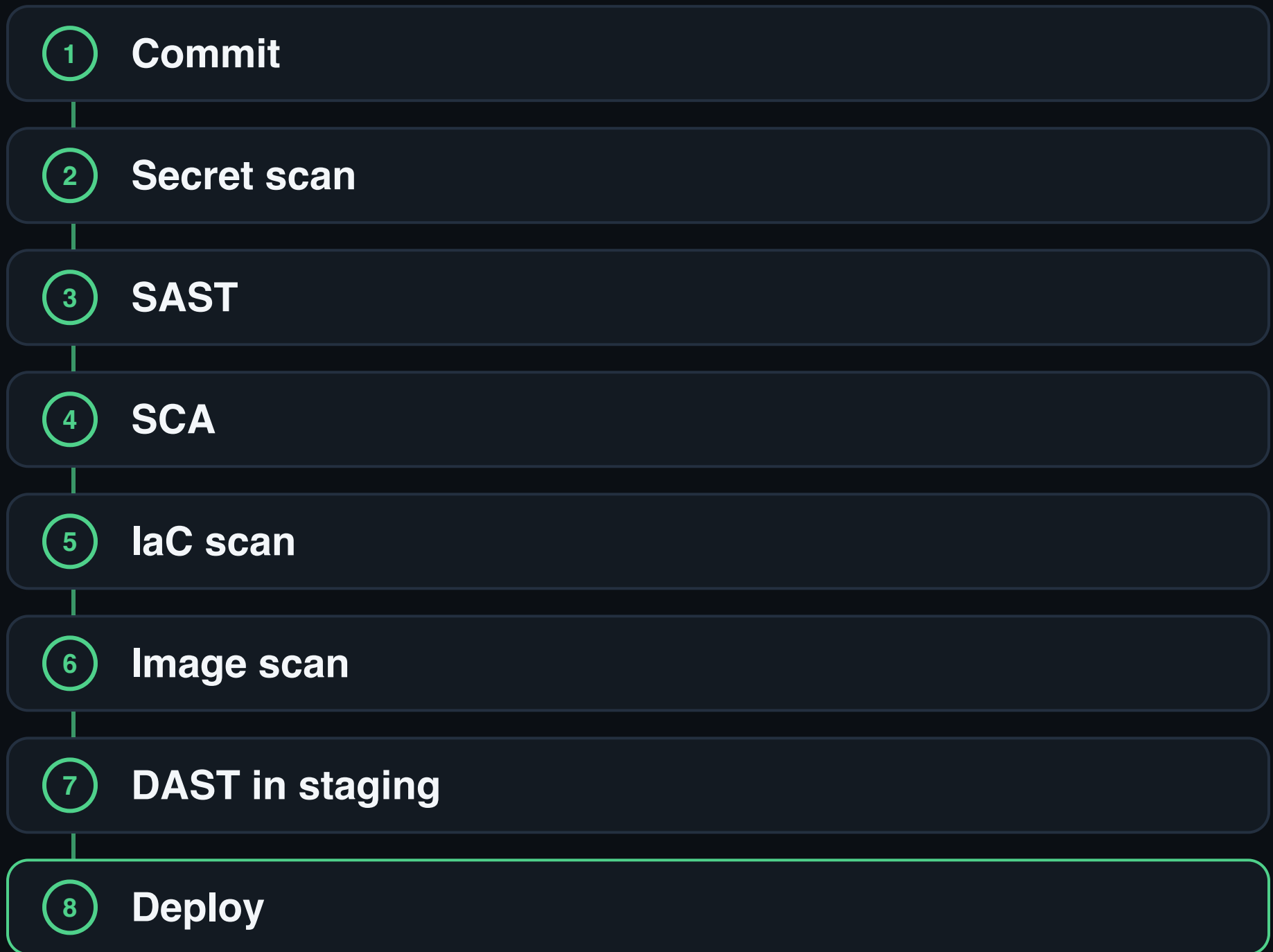
AR

Akhilesh Ranjan Singh

Senior DevSecOps Engineer · github.com/iarsingh

Swipe →

Where each scan runs



Fast checks on every PR. Slow checks nightly or in staging.

What blocks a merge

SCAN	STAGE	BLOCKS ON
Secrets	Pre-commit + PR	Any verified secret
SAST	PR	New high / critical
SCA	PR + nightly	Critical CVE with a fix
IaC	PR	Public storage, open ports
Image	Build	Critical OS CVEs
DAST	Staging	High findings



Managing the noise

DO

- ✓ Baseline existing findings
- ✓ Block only new issues
- ✓ Fix SLAs by severity
- ✓ Route findings to the owning team

AVOID

- ✗ Block every medium on day one
- ✗ Security as the only triager
- ✗ Exceptions without expiry
- ✗ Separate tools per team

Make it stick

01 Pipeline templates

Teams extend a shared template instead of copying scans.

02 Exceptions with expiry

Every waiver has an owner and an end date.

03 Per-team dashboards

Open criticals and age, visible to the team.

04 One metric

Time to fix critical findings.



Pipeline security baseline

- ☒ Secret scanning on every push
- ☒ SAST and SCA on every PR
- ☒ IaC scanning for Terraform
- ☒ Signed, scanned images
- ☒ DAST against staging
- ☒ Findings routed to owners
- ☒ Exceptions expire



KEY TAKEAWAY

Security that blocks only new risk is security developers keep.

- Right scan, right stage
- Baseline, then block new findings
- Templates over copy-paste

YOUR TURN

Which scan generates the most noise in your pipeline?

FOLLOW AKHILESH RANJAN SINGH

Next in the series: #02 Policy as code with OPA

Save · Repost

